

SIMATS ENGINEERING

ASSESSMENT TOOL – 3: CASE STUDY

COURSE CODE: ITA14

COURSE NAME: Ethical Hacking

COURSE OUTCOME: CO4 – Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux.

ASSESSMENT TOOL WEIGHTAGE: 35%

TOTAL MARKS: 100

NAME: K.Tejasri

REG. NO.:192371019

QUESTION 1

Security Assessment of an E-Commerce Web Application

Introduction

The e-commerce organization is experiencing suspicious customer activities and unauthorized transactions. Examination of the web-server logs has revealed unusual HTTP requests, attempts to discover restricted directories, and malicious content being entered into application fields.

The presence of an outdated Apache installation and the absence of a Web Application Firewall make the situation more serious. These weaknesses could provide attackers with several opportunities to compromise the application.

The important security issues identified are:

- Unsupported or outdated server software.
- Improper handling of user input.
- Possible SQL Injection and XSS vulnerabilities.
- Unnecessary directories or files being exposed.
- Weak application security controls.
- Lack of WAF protection.
- Insufficient monitoring and detection.

Attack Vectors

1. Outdated Apache Server

The web server may contain known security vulnerabilities because its software version is not current. An attacker can identify the version and investigate whether publicly documented vulnerabilities affect it.

Successful exploitation could result in:

- Unauthorized access.
- Information disclosure.
- Service disruption.
- Further compromise of the server.

Therefore, software version management is an important part of the assessment.

2. Directory Enumeration

The suspicious requests for hidden directories suggest that attackers may have tried to discover resources that are not linked from the main website.

Examples could include:

- Administration pages.
- Backup directories.
- Test folders.
- Upload locations.
- Configuration files.

Exposing such resources may provide useful information to an attacker.

3. Malicious Input

The attacker has attempted to place scripts into input fields. This suggests that the application may not properly validate or encode user input.

Such a weakness can lead to Cross-Site Scripting, allowing attacker-controlled content to be displayed in another user's browser.

4. Database Attacks

If application parameters are inserted into SQL queries without appropriate protection, SQL Injection may allow unauthorized interaction with the database.

5. Weak Authentication

Abnormal account activities may also indicate weaknesses in:

- Password policies.
- Session management.
- Authorization.
- Login protection.
- Multi-factor authentication.

Reconnaissance Using Kali Linux

The first stage of the assessment is information gathering.

Nmap can be used against the authorized target to identify exposed services.

Example:

```
nmap -sV -sC <AUTHORIZED-TARGET>
```

The scan can provide information about:

- Open ports.
- Running services.
- Service versions.
- Basic configurations.

The information collected should be compared against the approved assessment scope.

Web Server Assessment

Nikto can be used in a controlled environment to identify common web-server configuration problems.

Example:

```
nikto -h http://<AUTHORIZED-TARGET>
```

The results can indicate:

- Outdated software.
- Dangerous files.
- Missing security headers.
- Incorrect server configurations.
- Potentially exposed resources.

Burp Suite can then be used to inspect HTTP requests and responses.

Vulnerability Analysis

The tester should prioritize the findings according to risk.

Finding	Possible Consequence	Risk
Outdated Apache	Server compromise	High
SQL Injection	Database exposure	Critical
XSS	User/session attacks	High
Exposed directories	Information leakage	Medium/High

Finding	Possible Consequence	Risk
Weak authentication	Account takeover	High
No WAF	Reduced attack filtering	Medium

Controlled Vulnerability Validation

Testing should be performed only against systems for which permission has been obtained.

Using Burp Suite, the analyst can:

1. Intercept a normal HTTP request.
2. Identify parameters controlled by the user.
3. Send the request to Repeater.
4. Modify individual parameters.
5. Compare server responses.
6. Determine whether unexpected input is accepted.
7. Document the evidence.

The tester should avoid destructive actions and should stop after sufficient evidence has been obtained.

Recommended Security Architecture

Server Protection

The organization should:

- Upgrade Apache and other server components.
- Apply security patches regularly.
- Remove unnecessary services.
- Disable directory browsing.
- Delete unused test and backup files.
- Apply least-privilege permissions.
- Protect administrative interfaces.

Application Security

Developers should:

- Validate all incoming data.
- Use parameterized database queries.

- Encode output according to its context.
- Implement strong authorization.
- Secure file uploads.
- Protect authentication and sessions.

WAF

A WAF should be placed in front of the application to inspect incoming web traffic.

It can help identify suspicious patterns related to:

- SQL Injection.
- XSS.
- Directory traversal.
- Automated attacks.

Network Security

Additional controls should include:

- Firewall rules.
- IDS/IPS.
- Network segmentation.
- Secure administrator access.
- Continuous log monitoring.

Conclusion

The incident is most likely caused by several security weaknesses working together. An outdated web server, inadequate input handling, exposed resources, and missing protective controls can significantly increase the attack surface.

The organization should adopt a defense-in-depth model involving secure coding, patch management, server hardening, WAF protection, network controls, monitoring, and regular security assessments.

QUESTION 2

Assessment of SQL Injection and Cross-Site Scripting

Introduction

The financial application stores highly sensitive customer and transaction information. The discovery of SQL Injection and XSS vulnerabilities creates a significant security risk.

The exposure of database errors makes the situation even more dangerous because technical information about the backend may be revealed to attackers.

SQL Injection Vulnerability

SQL Injection occurs when an application treats user-controlled data as part of a database command instead of treating it only as data.

Possible vulnerable locations include:

- Login forms.
- Search functionality.
- Account identifiers.
- Transaction-related parameters.
- URL parameters.

An attacker may manipulate an input and observe how the application responds.

SQL Injection Assessment Using Burp Suite

Step 1 – Capture Traffic

Open the application through a browser configured to use Burp Suite.

Step 2 – Identify Input Parameters

Look for parameters that are sent to the server.

Step 3 – Send to Repeater

The request can be moved to Repeater for controlled testing.

Step 4 – Modify Input

The tester changes one input at a time and compares the resulting response.

Step 5 – Examine Errors

Unexpected database errors may reveal information about:

- Database technology.
- Query structure.
- Table names.
- Application implementation.

Step 6 – Confirm the Finding

The tester should determine whether the observed behavior is actually caused by SQL Injection and document the evidence.

SQLmap

SQLmap can be used for automated validation in an authorized testing environment.

For example:

```
sqlmap -u "http://<AUTHORIZED-LAB>/product?id=1" --batch
```

SQLmap can help determine whether a parameter is susceptible to SQL Injection.

Testing should be limited to the authorized target and should avoid unnecessary extraction or modification of real customer information.

Cross-Site Scripting

XSS occurs when an application allows untrusted content to reach a browser without appropriate encoding or sanitization.

Three common forms are:

Reflected XSS

Input is immediately returned in a response.

Stored XSS

Input is stored by the application and displayed later to another user.

DOM XSS

Unsafe client-side JavaScript processes attacker-controlled data.

XSS Testing with Burp Suite

The tester can:

1. Identify input fields.
2. Submit harmless test data.
3. Determine where the input is reflected.
4. Check whether output is encoded.
5. Inspect the HTTP response.
6. Determine whether the input is interpreted as active content.
7. Record the vulnerability and its location.

Testing should use non-destructive proof-of-concept input.

CIA Triad Assessment

Confidentiality

SQL Injection may expose:

- Customer records.
- Account information.
- Database contents.
- Sensitive financial information.

XSS may expose information accessible within a victim's browser context.

Integrity

An attacker who gains unauthorized database access may modify records.

XSS may also manipulate content displayed to users.

Availability

Abusive database queries or malicious application requests may affect performance or cause service disruption.

Therefore, both vulnerabilities can have significant business impact.

Security Improvements

1. Use Prepared Statements

Database queries should use parameterized statements rather than combining raw user input with SQL commands.

2. Validate Input

Applications should check:

- Expected type.
- Length.
- Format.
- Allowed values.

3. Encode Output

Output should be encoded based on its context before being sent to the browser.

4. Implement Content Security Policy

CSP can provide an additional layer of protection against many XSS scenarios.

5. Secure Cookies

Sensitive session cookies should use appropriate security attributes such as:

- Secure.

- HttpOnly.
- SameSite.

6. Improve Session Management

Sessions should have:

- Appropriate expiration.
- Secure identifiers.
- Session rotation after authentication.
- Proper logout and invalidation.

7. Hide Technical Errors

Users should receive generic error messages instead of database or framework details.

8. Additional Security Controls

The organization should also use:

- WAF.
- MFA.
- Rate limiting.
- Security logging.
- IDS/IPS.
- Regular penetration testing.
- Secure code reviews.

Conclusion

SQL Injection and XSS can expose sensitive information and compromise the trustworthiness of a financial application. Burp Suite is useful for manually examining application traffic, while SQLmap can assist with controlled SQL Injection validation.

Prevention should focus on secure coding, parameterized queries, input validation, output encoding, secure sessions, and continuous security monitoring.

QUESTION 3

Investigation of an Evil Twin Wireless Attack

Introduction

Employees have reported unusual authentication screens and unreliable wireless connectivity. The security investigation identified an unauthorized access point using the same SSID as the organization's legitimate wireless network.

This situation is characteristic of an Evil Twin attack.

How the Attack Occurs

The attacker creates a wireless network that resembles the organization's legitimate network.

A typical sequence is:

1. Identify the legitimate wireless SSID.
2. Create a rogue access point with a similar identity.
3. Position the rogue device within range of users.
4. Encourage or cause users to connect to it.
5. Present a fake authentication page or redirect users.
6. Collect credentials entered by victims.
7. Attempt to observe or manipulate traffic that is not adequately protected.

The attack relies heavily on user trust and insufficient wireless authentication controls.

Weaknesses in WPA2-PSK

WPA2-PSK uses a shared secret among users.

This can create several problems:

- The password may be shared.
- Employees may accidentally disclose it.
- Individual user accountability is limited.
- Password rotation can be difficult.
- Users may connect to networks based only on the SSID.

A shared password does not provide strong protection against a fraudulent network being given the same SSID.

Aircrack-ng Assessment

Aircrack-ng can be used during an authorized wireless assessment to examine wireless networks.

The security analyst can collect information such as:

- SSID.
- BSSID.
- Channel.

- Encryption.
- Signal strength.
- Authentication configuration.

If an unexpected access point advertises the same SSID, the security team can investigate whether it is legitimate.

Wireshark Investigation

Wireshark can be used to examine captured wireless traffic.

The analyst can study:

- Beacon frames.
- Probe traffic.
- Association activity.
- Authentication events.
- DHCP communication.
- DNS requests.
- Other authorized network traffic.

Comparing the legitimate access point with the suspected rogue device can provide useful evidence.

MITM Risk

When a victim connects to an attacker-controlled network, the attacker may be able to position themselves between the victim and external services.

Potential consequences include:

- Credential harvesting through fraudulent pages.
- Traffic observation.
- DNS manipulation.
- Redirection.
- Collection of device information.

However, correctly implemented HTTPS protects the confidentiality and integrity of properly encrypted application traffic.

Recommended Countermeasures

WPA3-Enterprise

The organization should consider WPA3-Enterprise for environments that support it.

802.1X

Individual user authentication provides stronger identity control than a shared PSK.

Certificate Validation

Users and managed devices should verify authentication-server certificates rather than accepting unexpected certificates.

Wireless IDS/IPS

Wireless monitoring can identify:

- Rogue APs.
- Duplicate SSIDs.
- Suspicious wireless devices.
- Evil Twin behavior.

Network Segmentation

Separate networks should be created for:

- Employees.
- Guests.
- IoT devices.
- Administrative systems.

Employee Awareness

Users should be trained to:

- Verify approved wireless networks.
- Report repeated login prompts.
- Avoid suspicious authentication pages.
- Report unexpected Wi-Fi behavior.

Conclusion

The Evil Twin incident demonstrates that a familiar SSID does not guarantee that a network is legitimate. Enterprise authentication, certificate validation, rogue-AP monitoring, segmentation, and user awareness should be combined to reduce the risk.

QUESTION 4

Penetration Testing of a Wireless Employee Management System

Introduction

The employee management application is reachable through a corporate Wi-Fi network. The wireless password is weak and the application itself has inadequate authentication and session controls.

This creates a possible multi-stage attack path from wireless access to sensitive employee information.

Attack Chain

The overall sequence can be represented as:

Wireless Weakness → Network Entry → Host Discovery → Service Enumeration → Web Assessment → Authentication Bypass/Authorization Weakness → Privilege Escalation → Confidential Data Exposure

Phase 1 – Wireless Assessment

The first step is to evaluate the security of the wireless network.

The assessment should determine:

- Authentication type.
- Encryption configuration.
- Password strength.
- Unauthorized APs.
- Connected devices.

Aircrack-ng tools can be used in an authorized wireless laboratory to analyze the configuration.

The purpose is to determine whether unauthorized access is realistically possible.

Phase 2 – Network Reconnaissance

Once authorized access is established, the tester can identify hosts on the test network.

Example:

```
nmap -sn <AUTHORIZED-LAB-NETWORK>
```

After identifying the test server, service enumeration can be performed:

```
nmap -sV <AUTHORIZED-TARGET-IP>
```

The tester records the available services and their versions.

Phase 3 – Web Application Discovery

The application should be examined for:

- Login pages.
- Employee functions.
- Administrative pages.
- API endpoints.
- Hidden resources.
- Session mechanisms.
- Authorization controls.

Burp Suite can be used to capture and analyze application requests.

Phase 4 – Authentication Assessment

The tester evaluates whether:

- Weak passwords are accepted.
- Login attempts are properly restricted.
- MFA is available.
- Sessions are securely created.
- Logout invalidates the session.
- Password-reset mechanisms are protected.

Authentication controls should be tested without attempting unauthorized access to real accounts.

Phase 5 – Authorization Testing

Authentication and authorization are different.

Authentication asks:

"Who is the user?"

Authorization asks:

"What is the user allowed to do?"

A major weakness would occur if a normal employee account could access functions intended only for administrators.

Phase 6 – Privilege Escalation

Privilege escalation can occur when the application does not enforce permissions on the server.

Potential causes include:

- Missing access-control checks.
- Insecure object references.
- Role information being trusted from the client.
- Improper session management.
- Weak administrative controls.

The tester should demonstrate the issue using test accounts rather than real employee information.

Phase 7 – Data Exposure

If access controls are bypassed, confidential information could potentially be exposed.

Examples include:

- Employee personal information.
- Salary information.
- Contact details.
- HR documents.
- Internal reports.

This represents a major confidentiality risk.

Kali Linux Tools

Assessment Phase	Tool	Main Purpose
Wireless analysis	Aircrack-ng	Examine wireless security
Host discovery	Nmap	Find active systems
Service identification	Nmap	Identify network services
Web testing	Burp Suite	Analyze HTTP traffic
Web-server checks	Nikto	Find common server weaknesses
SQL Injection validation	SQLmap	Test SQL injection
Traffic analysis	Wireshark	Inspect authorized network traffic

Defense-in-Depth Solution

Wireless Security

- WPA3-Enterprise.
- 802.1X.
- Strong authentication.
- Rogue-AP monitoring.
- Strong credential policies.

Network Protection

- VLAN segmentation.
- Network Access Control.
- Firewalls.
- IDS/IPS.
- Restricted administrative services.

Application Protection

- MFA.
- RBAC.
- Strong session management.
- Server-side authorization.
- Input validation.
- Output encoding.
- Secure password storage.

Data Protection

- Encryption.
- Least-privilege database accounts.
- Access logging.
- Secure backups.
- Restricted database access.

Monitoring

The organization should centrally monitor:

- Authentication events.
- Administrative actions.
- Network connections.

- Security alerts.
- Abnormal data access.

Conclusion

The case shows how attackers can combine weaknesses from different security layers. A weak wireless network can provide initial access, while poor web authentication and authorization can allow the attacker to reach confidential information.

The organization should therefore secure wireless, network, application, and data layers simultaneously.

QUESTION 5

Analysis of Wireless Deauthentication Attacks

Introduction

The university is experiencing repeated Wi-Fi disconnections, particularly during busy periods. Investigation suggests that an attacker is repeatedly sending forged deauthentication management frames.

The objective of the attacker is to make legitimate clients disconnect from wireless access points, resulting in a Denial-of-Service condition.

Nature of the Attack

Wireless networks use management frames to control connections between clients and access points.

In configurations without adequate management-frame protection, an attacker may forge deauthentication frames.

The affected client may interpret these frames as legitimate and disconnect.

If the attacker repeatedly sends them, users can experience continuous connection interruptions.

Attack Sequence

The attack can be understood as:

1. Identify the target wireless network.
2. Observe wireless clients and access points.
3. Generate unauthorized management traffic.
4. Clients receive forged deauthentication messages.
5. Wireless connections are terminated.

6. Clients attempt to reconnect.
7. The attacker repeats the process.
8. Continuous disruption occurs.

The primary objective is availability disruption rather than direct data theft.

Kali Linux-Based Analysis

The assessment should be carried out in a controlled wireless laboratory or with explicit authorization.

Aircrack-ng

Aircrack-ng can help analysts examine:

- Wireless networks.
- Channels.
- Access points.
- Clients.
- Wireless traffic.

It can also assist with controlled wireless security testing.

Wireshark

Wireshark can be used to analyze captured traffic.

The security analyst can investigate:

- Frequency of deauthentication frames.
- Source and destination addresses.
- Timing patterns.
- Sudden increases in management traffic.
- Repeated client disconnections.

Indicators of an Attack

Possible indicators include:

- Multiple users disconnecting simultaneously.
- Clients repeatedly reconnecting.
- Large numbers of deauthentication frames.
- Unusual wireless management traffic.

- Unexpected wireless devices.
- High frequency of authentication attempts.

Administrators should compare wireless captures with access-point logs to distinguish malicious activity from normal network problems.

Effect on CIA Triad

Availability

This is the most directly affected security property.

Users may be unable to access the network.

Confidentiality

The attack itself primarily targets availability. However, attackers may combine disruption with other attacks to encourage users to connect to unauthorized networks.

Integrity

Deauthentication alone does not normally modify application data, but it can be part of a broader attack chain.

Mitigation Measures

1. Protected Management Frames

PMF should be enabled where supported.

This provides protection for important wireless management traffic and makes certain spoofing-based attacks more difficult.

2. WPA3

Modern wireless security protocols should be preferred over older configurations where compatible.

3. Wireless IDS/IPS

A monitoring system can detect abnormal patterns such as:

- Deauthentication floods.
- Rogue APs.
- Unexpected wireless devices.
- Suspicious management traffic.

4. Firmware Updates

Wireless access points should be regularly updated to receive security fixes and improvements.

5. Network Segmentation

Separate wireless networks should be used for:

- Students.
- Staff.
- Guests.
- Administrative systems.

6. Monitoring

The university should monitor:

- Client disconnect rates.
- Authentication failures.
- AP status.
- Wireless management traffic.
- Security alerts.

Incident Response

If a deauthentication attack is detected, the security team should:

1. Confirm the abnormal traffic.
2. Identify affected access points.
3. Examine wireless monitoring data.
4. Preserve relevant logs.
5. Investigate the suspected source.
6. Apply appropriate network controls.
7. Continue monitoring.
8. Document the incident and corrective actions.

User Awareness

Students and employees should be instructed to report:

- Repeated unexpected disconnections.
- Unknown wireless networks.
- Repeated login requests.
- Suspicious network behavior.

Awareness helps the security team identify attacks more quickly.

Conclusion

Deauthentication attacks can cause serious wireless service interruptions and reduce productivity across a university campus.

The organization should use modern wireless security, Protected Management Frames, wireless intrusion monitoring, segmentation, regular firmware updates, and an effective incident-response process.